

**LOMBA KOMPETENSI SISWA
SEKOLAH MENENGAH KEJURUAN
TINGKAT PROVINSI JAWA BARAT
TAHUN 2023**



**NASKAH SOAL
(Terbuka / Tertutup)**

**Bidang Lomba
CYBER SECURITY**



**PEMERINTAH DAERAH PROVINSI JAWA BARAT
DINAS PENDIDIKAN**

Jl. Dr. Radjiman No. 6 Telp. (022) 4264813 Fax. (022) 4264881
Wisselbord (022) 4264944, 4264957, 4264973
Bandung (40171)



LOMBA KOMPETENSI SISWA SMK PROVINSI JAWA BARAT TAHUN 2023

Kisi Kisi Mata Lomba Cyber Security Soal Praktek (Hardening, VPN, Email security dan CTF 1,5 hari) Wawancara (1/2 hari)

1. Peserta Lomba

Peserta Lomba adalah Perwakilan dari Masing - Masing SMK Se Provinsi Jawa Barat yang telah mendaftar dan diverifikasi Panitia.

Alat dan bahan yang harus dibawa oleh setiap peserta lomba untuk pelaksanaan LKS Mata Lomba Cyber Security yaitu sebagai berikut:

- Laptop dengan spesifikasi minimal RAM 8 Gb

2. Tata Tertib Lomba

- Pembimbing diharapkan :
 1. Memberikan kisi-kisi materi yang akan diujikan sebelum hari H pelaksanaan lomba.
 2. Menjelaskan secara detail kisi-kisi dan soal.
 3. Jujur dan adil baik dalam memberikan arahan, penjelasan, maupun penilaian kepada peserta lomba.
- Peserta diharapkan :
 1. Memahami dasar-dasar kompetensi keamanan siber secara mendalam.
 2. Mempersiapkan diri pada soal teori dan pratikum sebelum mengikuti acara lomba
 3. Menyelesaikan seluruh soal dengan sebaik-baiknya dan dengan motivasi yang tinggi.
 4. Jujur dan sportif.
 5. Mematuhi tata tertib yang telah ditentukan oleh panitia atau juri, apabila melanggar maka akan dikenakan sanksi.

3. Skema Penilaian

- Disampaikan menjelang Hari Pelaksanaan

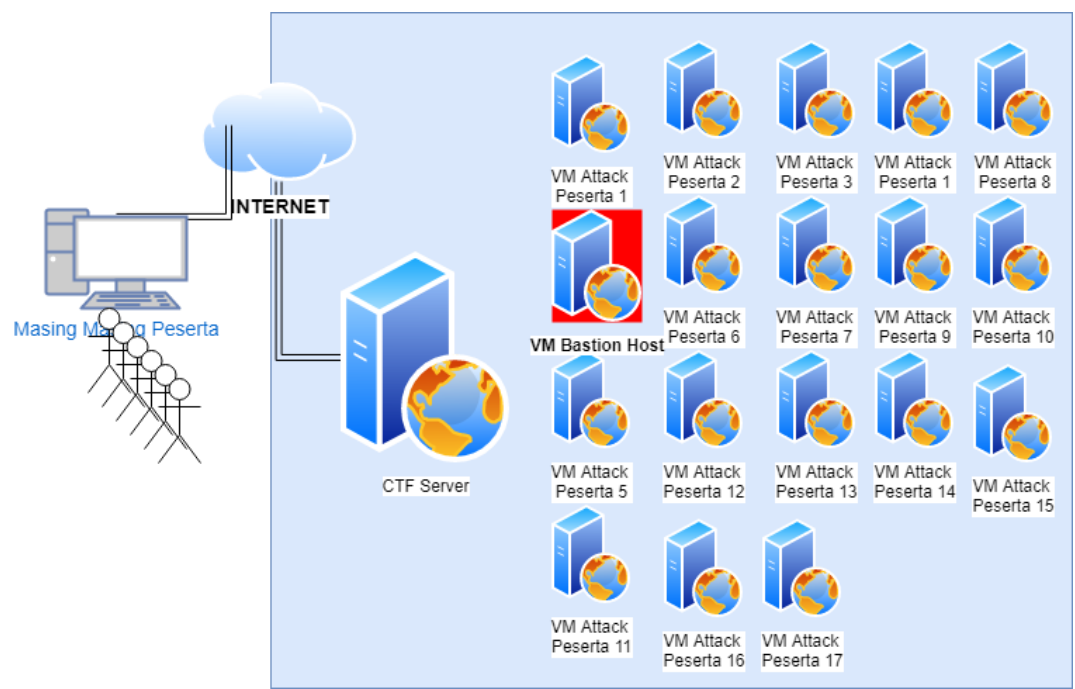
4. Dokumentasi Peserta

- Semua Point Penilaian akan dihitung apabila setiap peserta mampu menuangkannya dalam Dokument yang dapat mewakili Proof of Concept terjadinya *Threat, Vulnerability, Attack*

5. Hal hal yang dilarang

- Bekerjasama dengan Peserta lain / Competitor
- Dilarang meninggalkan hasil perubahan atau penambahan file atau penyisipan Backdoor setelah Penetrasi selesai
- Menggunakan tools Pemindaian otomatis

6. Gambaran Umum Soal Uji Praktek



Peserta menggunakan computer yang dibawa sendiri dalam menjalankan lomba Cyber Security Tingkat Provinsi Jawa Barat. Nantinya peserta akan diminta untuk bekerja di virtual machine menggunakan image yang fresh install. Peserta akan terkoneksi ke jaringan Private CTF server. Jenis soal terbagi menjadi 3 bagian yaitu CTF, Hardening dan Interview. Dokumentasi Sistem Menjadi Penilaian tersendiri dan memiliki bobot skor, dokumentasi harus dapat mendokumentasikan Proof of Concept, Metodology dan Table Vulnerability, Attack, Mitigation. Setiap jawaban benar dari soal CTF maupun hardening akan diberi skor apabila sudah tertuang dalam bentuk dokumentasi

7. Hardening Linux

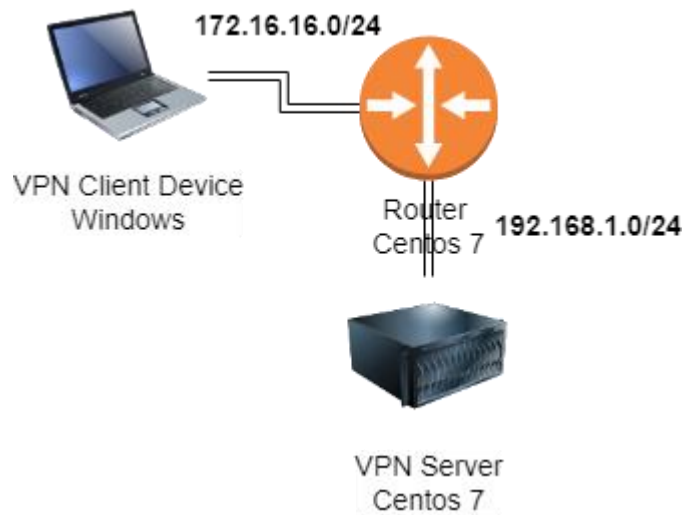
- Dijalankan di VM Masing Masing Komputer / Laptop Peserta. Dimulai dari tahapan Instalasi Sistem Operasi Linux Centos 7 (VMware / Virtualbox Masing masing)
- Pada Kondisi Awal Peserta Harus dapat Membuktikan secara terbalik (Reverse) tentang Vulnerabilitynya
- Konfigurasi dan Pengujian Hardening Document Host Information (Linux machines)
- Konfigurasi dan Pengujian Hardening Hardisk Encription (Linux machines)
- Konfigurasi dan Pengujian Hardening Closed Unusual Open Port (Linux machines)
- Konfigurasi dan Pengujian Hardening Whitelisting Selinux (Linux machines)
- Konfigurasi dan Pengujian Hardening CHROOT Shell (Linux machines)
- Konfigurasi dan Pengujian Hardening Certificate Shell Login (Linux machines)
- Konfigurasi dan Pengujian Hardening Directory Listing (Linux machines)
- Konfigurasi dan Pengujian Hardening Remote Command Exec (Linux machines)

8. Pengiriman Email PGP

Menggunakan VM Windows / OS / Laptop / Komputer Masing Masing Peserta (VMware / Virtualbox Masing masing)

- Digital Signature
- Encryption + Signing
- Decrypt
- Verification

9. Konfigurasi OpenVPN



- Instalasi dan Konfigurasi OpenVPN pada VM Linux dengan Protokol Standar
- Membuat Sertifikat File Client
- Konektifitas VPN Client dapat Berjalan di Background
- Uji Konektifitas OpenVPN
- VM Linux Centos 7 (VMware / Virtualbox Masing masing)

10. IDS (SNORT / Suricata)

- Diletakan di mesin Linux Centos 7 Peserta. (VMware / Virtualbox Masing masing)
- Instalasi dan Konfigurasi Instruction Detection System (IDS) pada web server
- Penambahan / Aktifasi Rule SQL Injection / Blind SQL Injection, Brute Force Attack dan Cross Site

Scripting

- Ujicoba Terbalik Attack dan Defence

11. Modevasive

- Peserta harus bisa buktikan log percobaan DOS yang dibuat sendiri
- Instalasi Konfigurasi Module ModEvasive
- Customisasi Parameter ModEvasive
- Instalasi Konfigurasi Module ModSecurity
- Customisasi Parameter / Rule ModEvasive
- Diletakan di mesin Linux Centos 7 Peserta. (VMware / Virtualbox Masing masing)

12. Analisis dan Patching Security Header Web

- Menyiapkan Sebuah file php berisi phpinfo(); pada sebuah web server di virtualbox / vmware masing masing peserta.
- Menemukan dan Menggunakan Tools untuk melakukan Pengecekan Security Header Web Server
- Peserta membuat sendiri aplikasi Web yang berisi info.php yang vulnerable disisi Header. Peserta harus mampu Mengaktifkan semua Mitigasi Security Header tanpa mengganggu Fungsionalitas Aplikasi
- Patching Strict-Transport-Security pada Apache
- Patching X-Frame-Options pada Apache
- Patching X-Content-Type-Options pada Apache
- Patching Referrer-Policy pada Apache
- Patching Permissions-Policy pada Apache
- Patching Content-Security-Policy (CSP) pada Apache
- Peserta akan mendeploy aplikasi yang disediakan panitia untuk di hardening di sisi Header web nya.

13. Capture The Flag

No	Deskripsi Kerentanan	Jumlah Flag
1	Kerentanan ini terjadi tidak adanya validasi terhadap paramater ke query database yang dapat menyebabkan penyerang untuk melihat atau mengunduh database di server target dan penyerang dapat melakukukan pengambilan alih server target.	2
2	Kerentanan ini terjadi dikarenakan path dari <u>.git</u> dapat dilihat oleh publik dan dapat di unduh oleh orang yang tidak berwenang	1
3	Kerentanan ini terjadi dikarenakan n dalam perubahan yang dilakukan pada normalisasi jalur di Apache HTTP Server 2.x.x.x (versi Http diinformasikan pada saat hari H). Penyerang dapat menggunakan serangan <i>path traversal</i> untuk memetakan URL ke file di luar root dokumen yang diharapkan. Jika file di luar direktori ini tidak dilindungi oleh konfigurasi default biasa "require all denied", permintaan ini dapat berhasil. Jika skrip CGI juga diaktifkan untuk jalur alias ini, ini dapat memungkinkan Dilakukannya serangan	1
4	Kerentanan ini terjadi dikarenakan penyerang dapat mengirim pesan <i>MSG_USERAUTH_SUCCESS</i> sebelum otentikasi berhasil. Itu dapat melewati otentikasi dan mengakses server SSH target	1
5	celah kerentanan di mana terdapat suatu endpoint Rest API yang menerima request data tidak terdapat validasi dengan baik, sehingga kita dapat memodifikasi request dengan menambahkan parameter lain yang terdapat pada resource database tersebut	1
6	Kerentanan ini memungkinkan penyerang/attacker untuk menyertakan file lokal yang tersimpan di server agar dapat menjadi bagian dari proses eksekusi aplikasi. Bahkan bisa melakukan <i>Remote Code Execution</i> .	1

7	menebak username dan password yang digunakan, pada target berikut adalah pada service SSH. dan melakukan <i>Local Privilege Escalation</i> dari user biasa ke root	2
8	fungsi "COPY TO/FROM PROGRAM" memungkinkan pengguna super dan pengguna dalam grup 'pg_execute_server_program' untuk mengeksekusi kode arbitrer dalam konteks pengguna sistem operasi database. Fungsionalitas ini diaktifkan secara default dan dapat disalahgunakan untuk menjalankan perintah sistem operasi yang sewenang-wenang di Windows, Linux, dan macOS.	1

14. Waktu Pelaksanaan Lomba

- Technical Meeting akan dilaksanakan pada tanggal 1 Mei 2023
- Lomba akan dilaksanakan pada tanggal 9 sampai 10 Mei 2023
(Jika ada perubahan jadwal akan kami sampaikan di grup whatsapp)
- Link zoom akan disampaikan nanti pada grup whatsapp

15. Penutup.

- Hal –hal yang belum tercantum dalam lembar informasi ini akan di informasikan pada waktu rapat teknis atau (*technical meeting*).